KOJI — Points à valider par la direction (Président / DG)

ABL Expert Renov, SAS — préparé par le développement (Amira) le 11 août 2026, mis à jour le 14 août 2026, en complément du document « Réponses aux informations requises v0.2 »

> **Objet.** Suite au questionnaire juridique du 6 août 2026, aux réponses techniques déjà préparées, et aux corrections de sécurité menées les 12 et 14 août, il reste des points qui nécessitent une validation rapide de la direction avant transmission finale au juriste — certains sont d'ordre technique/administratif (portés ici pour information et action), d'autres sont des choix commerciaux (tarifs, offre de lancement) ou des décisions liées aux corrections de sécurité récentes, présentés avec une recommandation du développement à valider ou ajuster.

1. Points techniques et administratifs restés ouverts

Réf.	Ce qui reste à faire	Qui agit
B3	Fixer le délai de récupération des données après résiliation d'un compte. *Proposition développement : 30 jours (cohérent avec la durée déjà utilisée pour l'accès aux liens de signature dans le code).*	Direction à valider
B7	Choisir le nom de domaine pour les adresses de contact et désigner qui relève chacune des 4 adresses (contact, support, protection des données, signalement). *Proposition d'Amira : nom de domaine _____ (à compléter avant envoi) — à valider par la direction.*	Direction
B8	Compléter le reste de la matrice de conservation. Durées légales déjà connues : pièces comptables 10 ans (art. L.123-22 code de commerce), prescription commerciale 5 ans (art. L.110-4). Restent à fixer : compte inactif, données client final après achèvement du chantier, tickets de support. *Proposition développement : compte inactif 3 ans, données client final 5 ans après le chantier, tickets support 3 ans — à valider avec le juriste.*	Direction + juriste
C1	Lancer la déclaration d'activité "édition de logiciel" auprès du courtier MIC pour la RC Pro.	Direction
C3	Lancer le dépôt de marque KOJI à l'INPI (recherche d'antériorité classes 9 et 42 au minimum).	Direction
C4	Clarifier le statut de Firas Mzoughi (salarié ou prestataire ponctuel) et déterminer avec le juriste si un contrat de cession de droits est nécessaire au regard de sa contribution.	Direction + juriste

2. Proposition tarifaire à valider

A. Formules actuelles (déjà en ligne dans l'application)

Formule	Prix mensuel	Fonctionnalités clés
Koji GO	19,99 €/mois	4 devis, versions illimitées par devis, génération PDF & Word, signature électronique, espace client particulier
Koji Premium (badge « populaire »)	49,99 €/mois	Devis illimités, versions illimitées, accès Marketplace, bibliothèque d'ouvrages avancée, gestion d'équipe, notifications SMS
Koji Business	99,99 €/mois	Accès illimité à tous les outils, devis et chantiers illimités, multi-utilisateurs, support prioritaire, intégration comptable, rapports personnalisés

À valider — HT ou TTC ?

☐ HT (recommandé — clientèle professionnelle, artisans du BTP récupérant la TVA, pratique standard en SaaS B2B français)

☐ TTC

B. Forfait annuel

Décision retenue : **pas de forfait annuel au lancement**. L'application reste en facturation mensuelle uniquement dans un premier temps ; un forfait annuel (avec remise, par exemple deux mois offerts) pourra être introduit ultérieurement si la demande le justifie. Aucun développement n'est nécessaire dans l'immédiat sur ce point.

C. Offre de lancement

Structure déjà actée : remise sur **la première période de facturation uniquement**, souscription manuelle, aucun prélèvement automatique sans validation expresse du client (cf. B4). Il reste à choisir le pourcentage et la fenêtre de validité — remplacée par une **durée limitée dans le temps** plutôt qu'un compteur de clients.

À valider — Pourcentage de la remise de lancement

☐ -30 %

☐ -50 % (option initialement envisagée)

☐ -70 %

☐ Autre : _____%

À valider — Durée de l'offre de lancement

☐ 1 mois après la mise en ligne

☐ 3 mois après la mise en ligne

☐ Jusqu'à une date fixe : _____

Recommandation développement : -50 % pendant les 3 premiers mois suivant le lancement — assez incitatif pour créer un signal d'urgence, sans devenir un engagement de trop longue durée à honorer.

3. Nouveaux points remontés lors des corrections de sécurité (12–14 août 2026)

Un audit de sécurité mené ces derniers jours a permis de corriger plusieurs failles actives (accès aux données d'une entreprise depuis une autre, base de données lisible sans connexion, mots de passe en clair, absence de session vérifiable). Le détail technique est dans le document de suivi séparé ; trois décisions issues de ce travail restent à valider par la direction.

D1 — Purge de l'historique Git

Constat : le fichier contenant une copie de la base de développement, avec plusieurs mots de passe réels en clair (dont celui du compte administrateur), a été retiré du suivi Git le 12 août et n'est plus versionné depuis. Il reste néanmoins visible dans les anciens commits (historique antérieur au 12 août 2026), consultable par toute personne ayant accès au dépôt.

À valider — Faut-il réécrire l'historique Git pour purger ces anciens commits ?

☐ Oui, à programmer dès que possible

☐ Non — dépôt privé, accès limité à l'équipe, risque résiduel jugé acceptable

☐ À réévaluer si le dépôt devient public ou change d'hébergement

Recommandation développement : oui — même dans un dépôt privé, toute personne ayant eu accès au dépôt (actuellement ou par le passé) a pu voir ces mots de passe réels. Cette opération réécrit l'historique et invalide les clones existants : à programmer à un moment où l'équipe peut re-cloner le dépôt sans perturber un travail en cours.

D2 — Évaluation d'une notification RGPD (violation de données)

Constat : jusqu'au 12 août 2026, la table de données de l'application était lisible par quiconque disposait de la clé publique du site (elle-même visible par tout visiteur, puisqu'elle est envoyée au navigateur), sans authentification — exposant les comptes utilisateurs et leurs mots de passe en clair, ainsi que d'autres données personnelles (ouvriers, clients). Corrigé côté code depuis le 12 août ; la fermeture complète côté base de données nécessite une commande SQL encore à exécuter par la direction (point technique séparé, non bloquant pour cette question).

À valider — Cette exposition constitue-t-elle une « violation de données à caractère personnel » au sens de l'article 4.12 du RGPD, nécessitant une notification à la CNIL sous 72h (art. 33) et/ou une information des personnes concernées (art. 34) ?

☐ Oui — à qualifier et notifier avec le juriste

☐ Non — risque jugé faible pour les droits et libertés des personnes (à documenter et justifier)

☐ Analyse à mener avec le juriste avant de trancher

Recommandation développement : cette question a une portée juridique et un délai légal court (72h à compter de la connaissance de la violation) — elle ne peut pas être tranchée par le développement seul et devrait être analysée en priorité

avec le juriste, indépendamment des autres points de ce document.

D3 — Réinitialisation des mots de passe existants

Constat : les mots de passe qui ont été exposés en clair jusqu'au 12 août restent valables tels quels pour les comptes qui n'en ont pas changé depuis.

À valider — Faut-il forcer une réinitialisation des mots de passe pour les comptes concernés (comptes professionnels, ouvriers, clients particuliers), par mesure de précaution ?

- ☐ Oui, à programmer
- ☐ Non

Recommandation développement : oui par précaution, en priorité pour les 3 comptes administrateurs de l'application.